

PUSH · SECURITY REVIEW

Push Fixes.

A security review of Fixes.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
Push	Fixes	Guardian	July 23 – August 10, 2026	August 17, 2026

§ 00

Contents.

14 pages — overview, confidence ranking, scope, 5 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 4 findings	P. 08
	Remediation Review · 1 finding	P. 12
§ 05	Disclaimer	P. 13
§ 06	About Guardian	P. 14

§ 01

Overview.

Guardian reviewed Fixes across 2 review rounds. The final report includes 2 Medium, 1 Low, 2 Informational findings.

AUDIT FIRM	REPOSITORY
Guardian	pushchain/push-chain-protocol-token-migration
CLIENT	METHODOLOGY
Push	Smart contract · Manual · Main Review · Remediation Review
PROJECT	MAIN REVIEW COMMIT
Fixes	0f39dede2075
PREPARED BY	REMEDIATION REVIEW COMMIT
Guardian	52ca929e382a
AUDIT WINDOW	
July 23 – August 10, 2026	
FINAL REPORT	
August 17, 2026	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.



1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	2	0	0	0	2
Low	1	0	1	0	0
Informational	2	0	2	0	0
All severities	5	0	3	0	2

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed Fixes in `pushchain/push-chain-protocol-token-migration`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH

Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM

Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW

Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH

Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM

Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW

Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
M-01	Unlocked ABI Mismatch Blocks Claim Building	DoS	MEDIUM	RESOLVED	p. 8
L-01	Pause Blocks Emergency Owner Operations	Best Practices	LOW	ACKNOWLEDGED	p. 9
I-01	Refund Mode Is Immutable After Initialization	Configuration	INFORMATIONAL	ACKNOWLEDGED	p. 10
I-02	Closed-Epoch Refunds Are Omitted	Logical Error	INFORMATIONAL	ACKNOWLEDGED	p. 11
REMEDIATION REVIEW					
M-01	Permissionless PUSH Donations Can DoS Claim Generation	DoS	MEDIUM	RESOLVED	p. 12

MEDIUM **M-01**

RESOLVED

Unlocked ABI Mismatch Blocks Claim Building

CATEGORY DoS

LOCATION <https://github.com/pushchain/push-chain-protocol-token-migration/blob/0f39dede2075bb9dfb22c493fa46dd9fa9eefc24/script/utils/config.js#L5-L10>

REVIEW Main Review

DESCRIPTION

The Solidity `Unlocked` event indexes `sender` and `recipient`, but the JavaScript builder ABI declares both parameters as non-indexed. As a result, the ABI does not match the emitted log format and Ethers cannot decode included refund events. Claim generation then fails when the builder processes the undecoded event.

RECOMMENDATION

Update the JavaScript `Unlocked` event ABI to mark `sender` and `recipient` as `indexed`, matching the Solidity event definition.

RESOLUTION

Status: Resolved.

<https://github.com/pushchain/push-chain-protocol-token-migration/pull/24/changes/52ca929e382a1a1ad5b07accb66801563c0d47d6>

LOW **L-01**

ACKNOWLEDGED

Pause Blocks Emergency Owner Operations

CATEGORY Best Practices

LOCATION <https://github.com/pushchain/push-chain-protocol-token-migration/blob/0f39dede2075bb9dfb22c493fa46dd9fa9eefc24/src/MigrationLocker.sol#L147-L178>

REVIEW Main Review

DESCRIPTION

`refundLockedFunds`, `burn`, and `recoverFunds` are restricted by both `onlyOwner` and `whenNotPaused`. If the locker is paused during an emergency, the trusted owner must first unpause it before performing these recovery operations. This unnecessarily reopens the public `lock` and `lockWithPermit` entrypoints until the owner pauses the contract again, weakening the pause mechanism as an emergency containment tool and requiring additional transactions.

RECOMMENDATION

Consider removing the `whenNotPaused` modifier from the `onlyOwner` recovery functions while retaining it on the user-facing locking functions.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL **I-01**

ACKNOWLEDGED

Refund Mode Is Immutable After Initialization

CATEGORY	Configuration
LOCATION	https://github.com/pushchain/push-chain-protocol-token-migration/blob/0f39dede2075bb9dfb22c493fa46dd9fa9eefc24/src/MigrationLocker.sol#L29-L62
REVIEW	Main Review

DESCRIPTION

`refundsEnabled` is configured only during initialization and cannot be changed afterward. Consequently, the trusted owner cannot enable or disable the refund path in response to changing operational requirements or an emergency without upgrading or replacing the locker implementation.

RECOMMENDATION

Consider adding a `setRefundsEnabled(bool)` function.

RESOLUTION

Status: Acknowledged.

INFORMATIONAL I-02

ACKNOWLEDGED

Closed-Epoch Refunds Are Omitted

CATEGORY	Logical Error
LOCATION	https://github.com/pushchain/push-chain-protocol-token-migration/blob/0f39dede2075bb9dfb22c493fa46dd9fa9eefc24/script/utils/fetchAndStoreEvents.js#L212-L250
REVIEW	Main Review

DESCRIPTION

The locker permits the owner to refund a balance from a historical epoch by passing an explicit `_epoch` to `refundLockedFunds`. However, once that epoch is closed, `getEpochWindow` restricts the builder query to `epochStartBlock(epoch + 1) - 1`. Any later `Unlocked` event referring to the closed epoch is therefore omitted.

RECOMMENDATION

Consider to either prohibit refunds from closed epochs or support them consistently in the builder.

RESOLUTION

Status: Acknowledged.

MEDIUM **M-01**

RESOLVED

Permissionless PUSH Donations Can DoS Claim Generation

CATEGORY DoS
LOCATION GLOBAL
REVIEW Remediation Review

DESCRIPTION

Anyone can transfer `PUSH` directly to a migration locker without calling `lock()`. This increases the locker balance without emitting a `Locked` event. The claim builder requires exact equality between `Locked - Unlocked` events and the raw balance delta, so even one base unit causes it to abort without generating claims.

A malicious actor can therefore delay claims.

RECOMMENDATION

Consider to not treat unexplained surplus `PUSH` as a fatal reconciliation error. Or to not allow users to freely transfer `PUSH` tokens into the contract.

RESOLUTION

Status: Resolved.

<https://github.com/pushchain/push-chain-protocol-token-migration/pull/24/changes/1b25bb78bca08629541ac886beb8c4420663ed45>

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.